

RaceDay API Endpoint Plan

PROG6212 Programming 2B — Part 1

1. Authentication

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
POST	/api/auth/register	Registers a new user (Organiser or Participant) with a hashed password.	None (Public)	{ email, password, firstName, lastName, phoneNumber, role }	201 Created — User object. 400 Bad Request. 409 Conflict — Email exists.
POST	/api/auth/login	Authenticates a user and creates a server-side session storing UserId and Role.	None (Public)	{ email, password }	200 OK — Session cookie set, user profile returned. 401 Unauthorized.
POST	/api/auth/logout	Destroys the current user session and clears the authentication cookie.	Any (Logged In)	None	200 OK — Logout confirmation message.

2. User Profile

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
GET	/api/users/profile	Retrieves the profile of the currently authenticated user.	Any (Logged In)	None	200 OK — User profile object. 401 Unauthorized.
PUT	/api/users/profile	Updates the authenticated user's personal information.	Any (Logged In)	{ firstName, lastName, phoneNumber }	200 OK — Updated profile. 400 Bad Request. 401 Unauthorized.

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
GET	/api/users/{id}	Retrieves a specific user's public profile by ID.	Any (Logged In)	None	200 OK — Public user details. 404 Not Found.

3. Events

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
GET	/api/events	Retrieves a list of all upcoming events with basic details.	None (Public)	None	200 OK — Array of event objects.
GET	/api/events/{id}	Retrieves full details for a specific event including its categories.	None (Public)	None	200 OK — Event object with nested categories. 404 Not Found.
POST	/api/events	Creates a new event. Only Organisers can create events.	Organiser	{ eventName, description, eventDate, location, distanceKm, eventType }	201 Created — New event. 400 Bad Request. 403 Forbidden.
PUT	/api/events/{id}	Updates an existing event. Only the owning Organiser can update.	Organiser	{ eventName, description, eventDate, location, distanceKm, eventType }	200 OK — Updated event. 403 Forbidden. 404 Not Found.
DELETE	/api/events/{id}	Deletes an event and all associated categories and enrolments.	Organiser	None	204 No Content. 403 Forbidden. 404 Not Found.
GET	/api/events/organiser/my-events	Retrieves all events created by the logged-in Organiser.	Organiser	None	200 OK — Events with enrolment counts. 403 Forbidden.

4. Categories

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
GET	/api/events/{eventId}/categories	Retrieves all categories defined for a specific event.	None (Public)	None	200 OK — Array of category objects. 404 Not Found.
POST	/api/events/{eventId}/categories	Adds a new category to an event. Only the event's Organiser.	Organiser	{ categoryName, description, minAge, maxAge, distance }	201 Created — New category. 403 Forbidden. 404 Not Found.
PUT	/api/categories/{id}	Updates an existing category. Only the event's Organiser.	Organiser	{ categoryName, description, minAge, maxAge, distance }	200 OK — Updated category. 403 Forbidden. 404 Not Found.

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
DELETE	/api/categories/{id}	Deletes a category. Only the event's Organiser.	Organiser	None	204 No Content. 403 Forbidden. 404 Not Found.

5. Event Enrolments

HTTP Method	Route	Description	Role/Requirement	Request Body	Expected Response
POST	/api/enrolments	Enrols the logged-in Participant into an event under a selected category.	Participant	{ eventId, categoryId }	201 Created — Enrolment record. 400 Bad Request. 409 Conflict. 403 Forbidden.
GET	/api/enrolments/my-enrolments	Retrieves all enrolments for the logged-in Participant.	Participant	None	200 OK — Enrolments with event and category details. 403 Forbidden.
GET	/api/events/{eventId}/enrolments	Retrieves all enrolments for a specific event. Only the event Organiser.	Organiser	None	200 OK — Enrolments with participant details. 403 Forbidden.
PUT	/api/enrolments/{id}/status	Updates the status of an enrolment (Pending, Confirmed, Cancelled).	Organiser	{ status }	200 OK — Updated enrolment. 403 Forbidden. 404 Not Found.

6. Results

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
POST	/api/results	Captures finish time and position for a participant's enrolment after an event.	Organiser	{ enrolmentId, finishTime, position }	201 Created — Result record. 400 Bad Request. 403 Forbidden. 409 Conflict.
GET	/api/results/my-results	Retrieves the logged-in Participant's personal race history.	Participant	None	200 OK — Results with event name, date, category, time, position. 403 Forbidden.
GET	/api/events/{eventId}/results	Retrieves all published results for a specific event.	Any (Logged In)	None	200 OK — Results ordered by position. 404 Not Found.
PUT	/api/results/{id}	Updates an existing result (e.g., corrected finish time).	Organiser	{ finishTime, position }	200 OK — Updated result. 403 Forbidden. 404 Not Found.

Endpoint Summary

Resource	Total Endpoints	Public	Any (Logged In)	Organizer	Participant
Authentication	3	2	1	0	0
User Profile	3	0	3	0	0
Events	6	2	0	4	0
Categories	4	1	0	3	0
Enrolments	4	0	0	2	2
Results	4	0	1	2	1
TOTAL	24	5	5	11	3

Design Decisions

- 1. Session-Based Authentication:** The API uses server-side sessions (not JWT) to maintain authenticated state across requests, as required by the assignment specification. The session stores *UserId* and *Role*.
- 2. Role Enforcement:** Every protected endpoint validates the session role before processing. Organiser endpoints explicitly check that the logged-in user is the owner of the resource (e.g., only the event creator can modify that event).
- 3. Password Hashing:** Passwords are hashed using BCrypt before storage. The API never returns the password hash in any response.
- 4. Enrolment Uniqueness:** A participant can only enroll once per event (enforced by the *UQ_Enrolment* constraint in the database and validated in the API).
- 5. Results 1:1 Mapping:** Each enrolment has exactly one result. The *EnrolmentId* in the Results table is marked *UNIQUE* to enforce this at the database level.
- 6. RESTful Conventions:** Routes use nouns (not verbs), proper HTTP methods, and nested resources where appropriate (e.g., `/api/events/{id}/categories`).